

SIMATS ENGINEERING

ASSESSMENT TOOL 1

COURSE NAME: Ethical Hacking

COURSE CODE: ITA14

COURSE OUTCOME COVERED

CO2: Foot printing Tools: Conducting Competitive Intelligence, DNS Zone Transfers, Introduction to Social Engineering: Social Engineering Attacks and Countermeasures. (BT3)

Assessment Tool Weightage: 30%

Duration: 90 min

Total Marks: 50

Report Analysis

Questions

1. A security analyst performed a network scan on the target 192.168.1.10 using the Nmap tool. The report identified several open ports, including HTTP (80), SSH (22), and MySQL (3306), along with the operating system and service versions. Analyze the report and explain the security risks associated with the identified services. Discuss how an attacker could exploit these services and recommend suitable security measures to protect the target system. **(20 Marks)**
2. A phishing awareness campaign was conducted for employees of ABC Technologies Pvt. Ltd. using the GoPhish tool. The report indicates that 40% of employees clicked the phishing link, 20% entered their login credentials, and several users downloaded a malicious attachment. Analyze the report and identify the security weaknesses demonstrated by the employees. Recommend suitable user awareness programs, email security controls, and organizational policies to reduce the risk of successful social engineering attacks. **(20 Mark)**.
3. A DNS assessment report generated using the Dig tool shows that the organization's DNS server permits a successful DNS Zone Transfer (AXFR), exposing internal hostnames, mail servers, and DNS records. Analyze the report and explain the security implications of the exposed information. Discuss how attackers could exploit these findings and recommend best practices to secure the DNS infrastructure.. **(10 Marks)**

Code of Conduct:

I Mokshitha Kilari(192525413) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

MokshithaKilari

Question 1: Nmap Network Scan Analysis

Objective

Analyze the Nmap scan results and identify security risks and suitable protections.

Tool Used

Nmap

Command Executed

```
nmap -sV -O 192.168.1.10
```

Sample Report

Starting Nmap 7.94
PORT STATE SERVICE VERSION
22/tcp open ssh OpenSSH 8.2
80/tcp open http Apache 2.4.41
3306/tcp open mysql MySQL 8.0.26
OS: Linux Ubuntu 20.04 LTS

Report Analysis

The scan reveals SSH, HTTP and MySQL services exposed to the network. The operating system and service versions are also disclosed, allowing attackers to identify known vulnerabilities. HTTP without HTTPS risks data interception, SSH may be vulnerable to brute-force attacks if weak credentials are used, and MySQL exposure can lead to unauthorized database access.

Security Risks

- Weak SSH credentials may allow brute-force attacks.
- HTTP may be vulnerable to SQL Injection, XSS and session hijacking.
- Public MySQL access may expose confidential data.
- OS and version disclosure aids targeted attacks.

Possible Exploitation

An attacker can enumerate services, exploit outdated software, brute-force SSH credentials, attack vulnerable web applications and access databases to steal or modify sensitive information.

Recommended Countermeasures

- Disable unused ports and services.
- Use HTTPS with SSL/TLS.
- Enable strong passwords and Multi-Factor Authentication.
- Disable SSH root login.
- Restrict MySQL to trusted hosts.
- Apply regular security patches.

Conclusion

Proper patching, access control, encryption and continuous monitoring significantly reduce the attack surface and improve system security.

Question 2: GoPhish Phishing Awareness Report

Objective

Evaluate employee susceptibility to phishing attacks and recommend improvements.

Tool Used

GoPhish

Command Executed

No command required (campaign executed through GoPhish web interface).

Sample Report

Emails Sent:100

Clicked Link:40

Credentials Submitted:20

Malicious Attachments Downloaded:12

Report Analysis

The campaign shows that many employees failed to recognize phishing emails. A significant number clicked malicious links, disclosed credentials and downloaded suspicious attachments, indicating inadequate cybersecurity awareness and unsafe email practices.

Security Risks

- High phishing susceptibility.
- Credential theft risk.
- Malware and ransomware infection.
- Potential unauthorized access to organizational systems.

Possible Exploitation

Attackers could use stolen credentials to access systems, deploy ransomware, steal confidential information and move laterally across the corporate network.

Recommended Countermeasures

- Conduct regular phishing awareness training.
- Run periodic simulated phishing campaigns.
- Implement Secure Email Gateway.
- Enable SPF, DKIM and DMARC.
- Use attachment sandboxing.
- Enforce Multi-Factor Authentication.
- Create strong incident reporting policies.

Conclusion

Combining user awareness with technical email security controls greatly reduces the success rate of phishing and social engineering attacks.

Question 3: DNS Zone Transfer (AXFR) Analysis

Objective

Analyze the impact of an exposed DNS Zone Transfer.

Tool Used

Dig

Command Executed

```
dig axfr example.com @192.168.1.53
```

Sample Report

```
example.com SOA
www.example.com A 192.168.1.20
mail.example.com A 192.168.1.30
ns1.example.com A 192.168.1.10
```

Report Analysis

The successful AXFR exposes internal DNS records including hosts, mail servers and infrastructure details. This information helps attackers understand the organization's network layout and identify valuable targets.

Security Risks

- Exposure of internal hostnames.
- Disclosure of mail servers and DNS records.
- Improved reconnaissance for attackers.
- Higher risk of targeted attacks.

Possible Exploitation

An attacker can map the network, identify critical servers, craft targeted phishing attacks and focus exploitation efforts on exposed systems.

Recommended Countermeasures

- Disable unauthorized AXFR.
- Allow zone transfers only to trusted DNS servers.
- Implement Access Control Lists.
- Enable DNSSEC.
- Patch DNS servers regularly.
- Monitor DNS logs.
- Perform regular DNS security audits.

Conclusion

Restricting DNS zone transfers and implementing DNS security best practices protects sensitive infrastructure information and reduces reconnaissance opportunities.

RUBRICS FOR CALCULATION

Report Analysis

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Report Analysis and Interpretation	25%	Accurately interprets the security report, identifies all key findings, and explains their significance with excellent technical understanding.	Correctly interprets most findings with minor omissions or inaccuracies.	Identifies only some findings and provides limited interpretation.	Unable to interpret the report or identify key findings.
Identification of Security Risks and Vulnerabilities	25%	Correctly identifies all security risks, vulnerabilities, and possible attack vectors with clear technical justification.	Identifies most risks and vulnerabilities with minor errors.	Identifies only a few risks with limited technical explanation.	Fails to identify major risks or vulnerabilities.
Application of Cybersecurity Concepts and Countermeasures	30%	Applies appropriate ethical hacking concepts and recommends comprehensive, practical, and technically sound countermeasures.	Recommends suitable countermeasures with minor technical gaps.	Provides limited or partially appropriate recommendations.	Recommendations are inappropriate, incomplete, or missing.
Technical Communication and Documentation	20%	Response is well-organized, technically accurate, clearly presented, and uses appropriate cybersecurity terminology throughout.	Response is organized and understandable with minor documentation or presentation issues.	Response lacks clarity, organization, or contains several technical inaccuracies.	Response is poorly organized, incomplete, and difficult to understand.